

ICS 33.030

CCS M 21

团体标准

T/TAF 209.6—2024

移动互联网应用程序（APP）合规开发管理 测评规范 第6部分：应用编程接口（API） 管理

Evaluation specification for compliance development of mobile Internet
application—Part 6: API

2024-02-23 发布

2024-02-23 实施

电信终端产业协会 发布

目 次

前言 II

引言 III

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 概述 2

5 API 接口开发管理要求..... 3

 5.1 需求阶段 3

 5.2 实现阶段 3

 5.3 维护阶段 3

6 评估方法 4

附录 A（资料性）常见 Android 操作系统 API 与个人信息对照 5

参考文献 7



前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规则起草。

本文件是T/TAF 209《移动应用程序（APP）合规开发管理测评规范》的第6部分。T/TAF 209已经发布了以下部分：

- 第1部分：总则；
- 第2部分：需求设计；
- 第3部分：功能测试；
- 第4部分：代码审计；
- 第5部分：对外接口管理；
- 第6部分：应用编程接口（API）管理；
- 第7部分：更新升级管理；
- 第8部分：数据使用管理；
- 第9部分：算法模型；
- 第10部分：人员能力；
- 第11部分：能力成熟度评估。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由电信终端产业协会提出并归口。

本文件起草单位：中国信息通信研究院、北京抖音信息服务有限公司、北京快手科技有限公司、蚂蚁科技集团股份有限公司、维沃移动通信有限公司、荣耀终端有限公司、北京微梦创科网络技术有限公司、北京三快科技有限公司。

本文件主要起草人：张静怡、安潇羽、王宇晓、杨骁涵、杜蕾、李昳婧、落红卫、王昕、林冠辰、任资政、靳鑫亚、李鸣雷、刘笑岑、田申、赵晓娜、赵盈洁、邹庆、王天、高龙、李辰淑、吴斌、王芳、冷杉、徐辉。

引 言

近年来，移动互联网应用程序个人信息保护事件频发，用户权益受到侵害。而移动应用程序开发过程中，各类API不规范、不合规的使用是导致问题的源头。

APP获取个人信息的途径通常分为通过移动智能终端提供的API获取和用户主动输入两种，其中通过API处理的个人信息种类繁多、敏感度高且用户无法直接感知是本文讨论的重点，同时APP提供个人信息上传和查询服务的API如果设置不当也存在个人信息滥用以及个人信息泄露的风险。因此需要编写本规范，为APP开发者规范APP开发过程中API接口合规使用提供方法，提升企业APP个人信息保护能力。

- T/TAF 209旨在对APP开发流程、功能模块、工程管理等提出合规开发管理要求，拟由11部分构成。
- 第1部分：总则。目的在于给出规范移动互联网应用程序（APP）合规开发的总体原则和要求。
 - 第2部分：需求设计。目的在于提出规范APP需求设计环节的相关合规开发要求。
 - 第3部分：功能测试。目的在于规范移动互联网应用程序（APP）在合规开发阶段满足功能测试的标准要求。
 - 第4部分：代码审计。目的在于规范APP代码审计过程，提升代码安全管理能力。
 - 第5部分：对外接口管理。目的在于规范APP对外接口的合规开发和使用管理，提升合规能力。
 - 第6部分：应用编程接口（API）管理。目的在于规范APP在开发过程中对于API的使用，提升合规能力。
 - 第7部分：更新升级管理。目的在于规范APP合规开发在更新升级阶段的要求，提升APP更新升级管理能力。
 - 第8部分：数据使用管理。目的在于规范APP在合规开发过程中数据使用的合规管理，提升数据使用合规管理能力。
 - 第9部分：算法模型。目的在于规范APP合规开发在算法模型方面的要求，提升APP算法模型开发的合规管理能力。
 - 第10部分：人员能力。目的在于规范APP在合规开发过程中的人员能力管理。
 - 第11部分：能力成熟度评估。目的在于规范APP在合规开发管理过程中的能力成熟度评估。

移动互联网应用程序（APP）合规开发管理测评规范 第6部分：应用编程接口（API）管理

1 范围

本文件规定了 APP 在开发过程中，对移动智能终端操作系统提供的获取个人信息 API 接口以及服务端提供查询上报个人信息的 API 接口使用的合规要求和测评方法。

本文件适用 APP 对其 API 接口使用进行设计、开发和评估，也适用于主管部门、第三方评估机构等组织对 APP 进行监督、管理和评估。

本文件要求限定范围为 APP 自身对于 API 的开发和使用，对于第三方 API 开发和使用不在本文要求范围内。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

T/TAF 078.1 APP用户权益保护测评规范 第1部分：超范围收集个人信息

3 术语和定义

下列术语和定义适用于本文件。

3.1

移动智能终端 smart mobile terminal

能够接入移动通信网，具有能够提供应用软件开发接口的操作系统，具有安装、加载和运行应用软件能力的终端。

3.2

移动应用软件 mobile application

可安装在移动智能终端内，能够利用移动智能终端操作系统提供的公开开发接口，实现某项或某几项特定任务的计算机软件，包含移动智能终端预置应用软件、小程序、快应用以及互联网信息服务提供者提供的可以通过网站、应用商店等应用分发平台下载、安装、升级的应用软件。

3.3

应用编程接口 Application Programming Interface, API

一组预先定义的功能，通过访问接口可实现不同程序之间的数据交互及功能调用。

3.4

收集 collect

获得个人信息的活动。

[来源：YD/T 4177.1，3.7]

3.5

个人信息 personal information

以电子或者其他方式记录的与已识别或者可识别的自然人有关的各种信息，不包括匿名化处理后的信息。

[来源：《中华人民共和国个人信息保护法》]

3.6

敏感个人信息 sensitive personal information

一旦泄露或者非法使用,可能导致自然人的人格尊严受到侵害或者人身、财产安全受到危害的个人信息，包括生物识别、宗教信仰、特定身份、医疗健康、金融账户、行踪轨迹等信息，以及不满十四周岁未成年人的个人信息。

[来源：《中华人民共和国个人信息保护法》]

3.7

用户 user

使用产品或服务的个人信息主体。

[来源：GB/T 25069—2022，3.733]

3.8

软件开发工具包 software development kit

协助软件开发的软件库，包括相关的二进制、文档、范例和工具的集合。

4 概述

本文对APP开发过程中可能使用的API接口进行分类，区分为本地API和远程API两种，分别提出其涉及用户个人信息时的合规开发使用要求。

本地API主要指APP在移动智能终端操作系统提供的API，远程API是指服务端提供，APP通过网络访问服务端资源的API。

远程API可直接获取的个人信息种类多样、敏感度高。远程API通过网络访问的方式上报和查询个人信息，滥用及泄漏风险高。同时，这两种处理方式用户感知度都较低，合规开发使用十分必要。

常见的APP可通过终端操作系统API采集个人信息的类型见表1。

表 1 常见 APP 通过终端操作系统 API 采集个人信息类型

序号	信息类型	示例
1	设备信息	IDFA、IDFV、IMEI、Android ID、MEID、IMSI、MAC 地址、Bluetooth ID、OAID、CAID、build_serial_number、ICCID
2	位置信息	GPS、基站信息、Wi-Fi 信息（SSID、BSSID）、附近 AP 接入点信息
3	传感器信息	传感器获取的与个人行为相关的信息
4	用户内容信息	手机号、短信、通话记录、通讯录、日历、相册、摄像头、麦克风、用户文件、应用安装列表、剪切板中的数据等

5 API 接口开发管理要求

5.1 需求阶段

APP开发运营者在API接口需求设计阶段的管理要求如下：

- a) 使用API收集、查询、上报个人信息应具有明确、合理、具体的个人信息处理目的并且与实现的功能直接相关；
- b) 使用API收集、查询、上报个人信息应限于实现处理目的所必要的最小范围，范围通常包括类型、频率、数量、精度等；
- c) 应在已征得用户同意的情况下使用API处理个人信息；
- d) 对于不依赖服务端且能在本地即可实现所有个人信息收集、查询、上报目的的个人信息则不应通过API上报服务端。

5.2 实现阶段

5.2.1 本地 API 要求

APP使用本地API对个人信息进行处理的要求如下：

- a) 应采用对用户个人权益影响最小的方式实现功能，能使用低敏感度信息实现功能的不使用高敏感度信息实现；

注1：能使用粗略个人信息实现功能的不使用精确数据API，能精准获取单条个人信息的不使用获取全部信息的API。

- b) 对于不可变设备标识符，在单次APP启动到退出的运行生命周期内，同一功能或目的应在调用API成功后不再重复获取；
- c) 应在用户触发相关功能或明确表示要使用某项功能的情况下再调用对应系统API获取个人信息，不应出现无合理场景的定时调用、静默状态自行调用API获取个人信息的情况；
- d) APP在调用API前应先检查用户以及用户对于该个人信息的授权状态，在有授权的情况下获取个人信息；

注2：授权状态分为用户是否同意了APP的个人信息处理规则状态以及用户是否同意了约束本地API的权限。例如调用getCurrentLocation前调用PackageManager.PERMISSION_GRANTED确认是否有location权限。

- e) 应遵守T/TAF 078.1中对于API使用的相关要求。

5.2.2 远程 API 要求

APP使用远程API对个人信息进行处理的要求如下：

- a) 服务端API接口应设置访问控制措施，包括不限于权限机制、身份认证以及必要的异常请求检测能力；
- b) 涉及个人信息的传输应采用加密协议，对于个人敏感信息的传输宜在协议加密的基础上采用字段级别加密等安全增加措施；
- c) 涉及查询/返回个人信息的服务端API应避免返回非预期的个人信息，例如接口可以越权查询其他用户的个人信息；
- d) 涉及查询个人信息的服务端API返回个人信息时，不应返回超过当前处理目的的个人敏感信息；

注：例如APP在展示用户头像的场景，通过调用服务端API查询用户自身头像，接口在返回用户头像的同时超范围返回用户的身份证号等信息。

5.3 维护阶段

API接口应满足如下管理和变更要求：

- a) 应通过系统或文档等方式妥善记录并更新维护自身的API资产的情况，包括但不限于API列表、版本、参数说明、用途等；
- b) 当API接口的用途发生变化时，应重新按照需求阶段的要求进行合理性评估。

6 评估方法

APP对API合规开发管理的测试方法主要采用资料审查、技术验证和人员访谈对各项要求进行符合性评估。管理规范与测评方式对应关系具体见表2。

表 2 管理规范与测评方式对应关系表

要求条款	测评方式		
	资料审查	技术验证	人员访谈
5.1 a)	√	—	√
5.1 b)	√	—	√
5.1 c)	√	—	√
5.1 d)	√	—	√
5.2.1 a)	√	√	—
5.2.1 b)	√	√	—
5.2.1 c)	√	√	—
5.2.1 d)	√	√	—
5.2.1 e)	√	√	—
5.2.2 a)	√	√	—
5.2.2 b)	√	√	—
5.2.2 c)	√	√	—
5.2.2 d)	√	√	√
5.3 a)	√	—	√
5.3 b)	√	—	√
注：“√”表示可采用的测评方式；“—”表示不适用。			

附 录 A
(资料性)
常见Android操作系统API与个人信息对照

表 A. 1 给出了常见 Android 操作系统 API 与个人信息对照关系。

表A. 1 常见Android操作系统API与个人信息对照

序号	信息类型	信息名称	系统 API
1	设备信息	IMEI	android.telephony.TelephonyManager.getDeviceId
2			android.telephony.TelephonyManager.getImei
3		设备序列号	android.os.Build.getSerial
4		ICCID	android.telephony.TelephonyManager.getSimSerialNumber
5			android.telephony.SubscriptionInfo.getIccid
6		MAC	<u>android.net</u> .wifi.WifiInfo.getMacAddress
7			<u>java.net</u> .NetworkInterface.getHardwareAddress
8		WIFI 列表	<u>android.net</u> .wifi.WifiManager.getScanResults
9		MEID	android.telephony.TelephonyManager.getMeid
10		IMSI	android.telephony.TelephonyManager.getSubscriberId
11		SSID	<u>android.net</u> .wifi.WifiInfo.getSSID
12			<u>android.net</u> .wifi.WifiInfo.toString
13			android.net.NetworkInfo.getExtraInfo
14		BSSID	<u>android.net</u> .wifi.WifiInfo.getBSSID
15		Android id	android.provider.Settings.Secure.getString#android_id
16			android.provider.Settings.System.getString#android_id
17			android.provider.Settings.Global.getString#android_id
18			android.content.ContentResolver.query#android_id
19		OAID	android.content.ContentResolver.query#oaid
20			android.content.ContextWrapper.bindService#oaid
21			android.provider.Settings.Global.getString#oaid
22			com.android.id.impl.IdProviderImpl.getOAID
23	位置信息	定位信息	android.location.LocationManager.getLastKnownLocation
24			android.location.LocationManager.getLastLocation
25			android.location.LocationManager.getCurrentLocation
26			android.location.LocationManager.requestLocationUpdates
27		基站信息	android.telephony.TelephonyManager.getNeighboringCellInfo
28			android.telephony.TelephonyManager.getAllCellInfo
29			android.telephony.TelephonyManager.getCellLocation
30	传感器信息	传感器数据	android.hardware.SensorManager.registerListener

表 A.1 常见系统 API 与个人信息对照关系（续）

序号	信息类型	信息名称	系统 API
31	用户内容 信息	应用安装列表	android.APP.ApplicationPackageManager.getInstalledPackagesAsUser
32			android.APP.ApplicationPackageManager.getInstalledApplicationsAsUser
33			android.APP.ApplicationPackageManager.getInstalledPackages
34			android.APP.ApplicationPackageManager.getInstalledApplications
35		电话号码	android.telephony.TelephonyManager.getLine1Number
36			android.telephony.TelecomManager.getLine1Number
37			android.telephony.SubscriptionInfo.getNumber
38			android.location.Address.getPhone
39		剪切板	android.content.ClipboardManager.getPrimaryClip
40		短信和彩信	android.content.ContentResolver.query#mms
41		读取通讯录	android.provider.ContactsContract.Contacts.lookupContact
42			android.provider.ContactsContract.Contacts.getLookupUri
43			android.provider.ContactsContract.Contacts.openContactPhotoInputStream
44			android.content.ContentResolver.query#contacts
45		日历	android.content.ContentResolver.query#calendar
46		通话记录	android.content.ContentResolver.query#call_log

参 考 文 献

[1] 《中华人民共和国个人信息保护法》
[2] GB/T 25069 信息安全技术 术语
[3] GB/T 35273 信息安全技术 个人信息安全规范
[4] YD/T 4177.1 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第1部分：
总则



电信终端产业协会团体标准

移动互联网应用程序（APP）合规开发管理评测规范
第 6 部分：应用编程接口（API）管理

T/TAF 209.6—2024

*

版权所有 侵权必究

电信终端产业协会印发
地址：北京市西城区新街口外大街 28 号
电话：010-82052809
电子版发行网址：www.taf.org.cn